

Firestore 오설정으로 인한 파일 노출 실태 분석

발행인: 화이트햇 스쿨 4기 닥스훈트 팀

발행일: 2026년 08월 29일

Executive Summary.....	3
Detailed Analysis.....	4
1. 조사 개요.....	4
1.1. Firebase Security Rules.....	4
1.2. 조사 범위.....	5
2. 조사 방법.....	5
2.1. Firebase 사용 서비스 수집.....	5
2.2. 접근제어 상태 점검.....	6
2.2.1 자동 점검 스캐너의 작동 원리.....	6
2.2.2. 노출 여부 판정 기준.....	6
2.2.3. 수동 검증.....	7
3. 탐지 결과.....	10
4. Firebase Storage Open 사례 및 위험 분석.....	12
4.1. 실제 파일 접근 사례 (npvplanner).....	13
4.2. 목록만 조회된 사례 (sc2006app).....	14
4.3. 다른 Firebase 서비스가 열린 사례 (akm-iot-firebase).....	15
4.4. 설정은 열려 있지만 실질 노출이 확인되지 않은 사례 (namsaiaan).....	16

Executive Summary

공개 웹에서 Firebase 설정 정보가 확인된 총 13개 서비스를 대상으로 Storage 및 Realtime Database의 접근제어 상태를 점검하였다.

자동화 스캐너를 통한 1차 점검과 수동 재검증 결과는 아래와 같다.

- 파일 목록 조회가 가능한 서비스 12개를 확인했다.
- 파일 다운로드가 가능한 서비스 4개를 확인했다.
- 이 중 설정은 열려 있으나 실제 파일이 존재하지 않아 노출까지 이어지지 않은 사례도 있었으며, 이는 파일이 업로드되는 즉시 노출로 전환될 수 있는 잠재적 위험으로 판단된다.

이러한 노출의 공통 원인은 개발 초기 테스트 편의를 위해 설정된 Security Rules (접근권한설정)의 전체 허용 설정이 배포 이후에도 방치된 데 있다.

Detailed Analysis

1. 조사 개요

1.1. Firebase Security Rules

Firebase는 웹이나 모바일 서비스를 개발할 때 필요한 서버 기능을 제공하는 구글의 백엔드 플랫폼¹이다. 별도의 서버 구축 없이 인증, 데이터베이스(Realtime Database²/Firestore), 파일 저장(Storage) 등의 기능을 웹 서비스에 연결할 수 있다.

웹 서비스가 Firebase 프로젝트에 연결하려면 일반적으로 다음 정보가 필요하다.

- **projectId**: 연결할 Firebase 프로젝트를 식별하는 값
- **apiKey**: 클라이언트 애플리케이션이 Firebase 서비스에 요청을 보낼 때 사용하는 값
- **storageBucket / authDomain**: 각각 Storage 저장소 위치와 인증 도메인을 나타내는 값

이러한 설정값만으로 모든 데이터에 접근할 수 있는 것은 아니다. 실제 접근 범위는 사용자의 로그인 상태와 누가 읽고 쓸 수 있는지를 정의하는 **Security Rules**에 따라 달라진다.

서비스	접근 판단 기준	Rules 오설정 시 위험
Storage	Storage Security Rules	인증 없이 파일 목록·개별 파일 읽기 허용
Realtime Database	RTDB Security Rules	인증 없이 전체 데이터 조회 가능
Firestore	Firestore Security Rules	인증 없이 컬렉션·문서 전체 조회 가능

[표 1-1] 서비스별 Rules 오설정 위험

Security Rules는 개발 초기 테스트 편의를 위해 **allow read, write: if true(전체 허용)**로 설정되는 경우가 많은데, 이것이 배포 이후에도 방치되면 로그인 없이 접근이 가능해진다

¹ **백엔드(Back-end)**: 사용자에게 직접 노출되지 않는 서버 측 처리 영역 (회원 인증, 데이터 저장)

² **실시간 바인딩(Real-time Binding)**: 데이터가 변경되는 즉시 연결된 모든 클라이언트에 자동으로 반영되는 방식.

1.2. 조사 범위

본 조사는 Firebase Storage 접근제어(Security Rules)가 제대로 설정되지 않아, 인증되지 않은 사용자가 파일에 접근할 수 있는 문제에 집중하였다. 인증 없이 Storage 파일 목록을 조회할 수 있는지, 나아가 개별 파일을 실제로 다운로드할 수 있는지를 확인하는 데 목적이 있다.

- 조사 대상: 공개 웹에서 확인 가능한 Firebase 기반 서비스
- 조사 제외: 업로드·수정·삭제, 인증 우회
- 최종 대상: 수동 탐색과 자동 스캐너 두 경로로 확보한 후보 중 실제 노출이 확인된 13개 사례

2. 조사 방법

2.1. Firebase 사용 서비스 수집

Firebase를 사용하는 웹페이지는 클라이언트 코드³에 **apiKey**, **projectId**, **storageBucket** 등이 포함된 **firebaseConfig** 형태의 설정값이 존재한다. 이 특징을 이용해 세 가지 경로로 후보 서비스를 수집하였다.

수집 경로	세부 방식
패턴 기반 자동 탐지	firebaseConfig 등 설정값 패턴을 자동 탐지하는 도구로 후보 URL 대량 수집
수동 검색	- 디스콰이엇 등 개발자·프로젝트 소개 플랫폼 직접 탐색 후 F12에서 firebase 문자열 확인 - site: ⁴ 등 구글 검색 연산자로 Firebase 관련 페이지 탐색

[표 2-1] Firebase 후보 웹 수집 경로

³ 클라이언트 코드: 사용자의 브라우저로 전송되어 실행되는 코드로, 개발자도구(F12) 등을 통해 누구나 열람할 수 있다.

⁴ site: 연산자: 구글 검색 시 특정 도메인이나 사이트 내의 페이지로 검색 범위를 한정하는 기능

2.2. 접근제어 상태 점검

2.2.1 자동 점검 스캐너의 작동 원리

위에서 확보한 후보를 대상으로, 인증 없이 Storage·RTDB·Firestore에 접근을 시도하고 그 응답을 자동으로 점검하였다.

- **projectId 확인:** 클라이언트 코드에 값이 있으면 그대로 사용, 없으면 도메인명(예: **xxx.web.app** → **xxx**)으로 추정
- **Storage 버킷⁵ 주소 확정:** 버킷 이름 형식이 **xxx.appspot.com(구버전)** 또는 **xxx.firebasestorage.app(신버전)** 두 형식 모두로 Storage API⁶ 목록 조회를 시도해 응답이 오는 쪽을 버킷으로 확정
- **Storage API 목록 조회:** 확정된 버킷에 `firebasestorage.googleapis.com/v0/b/{버킷}/o` 형식으로 인증 없이 List 요청을 보내 응답 코드(200/403/404 등)⁷로 개방 여부 확인
- **RTDB·Firestore도 동일한 방식으로 로그인 없이 응답이 오는지 확인**

⁵ **버킷(Bucket):** Storage에서 파일들이 저장되는 하나의 저장 공간 단위. 서비스마다 고유한 버킷 이름을 갖는다.

⁶ **API :** 서로 다른 프로그램이 데이터를 주고받을 수 있도록 정해놓은 통신 규격. 여기서는 Firebase가 제공하는 Storage 접근용 통신 방식을 의미한다.

⁷ **응답 코드:** 웹 요청에 대해 서버가 돌려주는 상태 값.

200은 "정상 응답(성공)", 403은 "접근 거부", 404는 "존재하지 않음", 402는 원래 "결제 필요"를 뜻하나 Firebase에서는 무료 요금제의 트래픽 한도 초과 시 반환되는 코드다.

2.2.2. 노출 여부 판정 기준

판정	조건
CRITICAL	Storage 등에서 로그인 없이도 응답(열림)이 확인됨 → 해당 대상은 CRITICAL로 확정, 다음 대상으로 진행
UNKNOWN	두 버킷 형식 모두 오류로 응답이 엇갈려 자동 판단이 어려움 → 수동 재확인 필요

[표 2-2] 스캐너 판정 기준(CRITICAL·UNKNOWN)

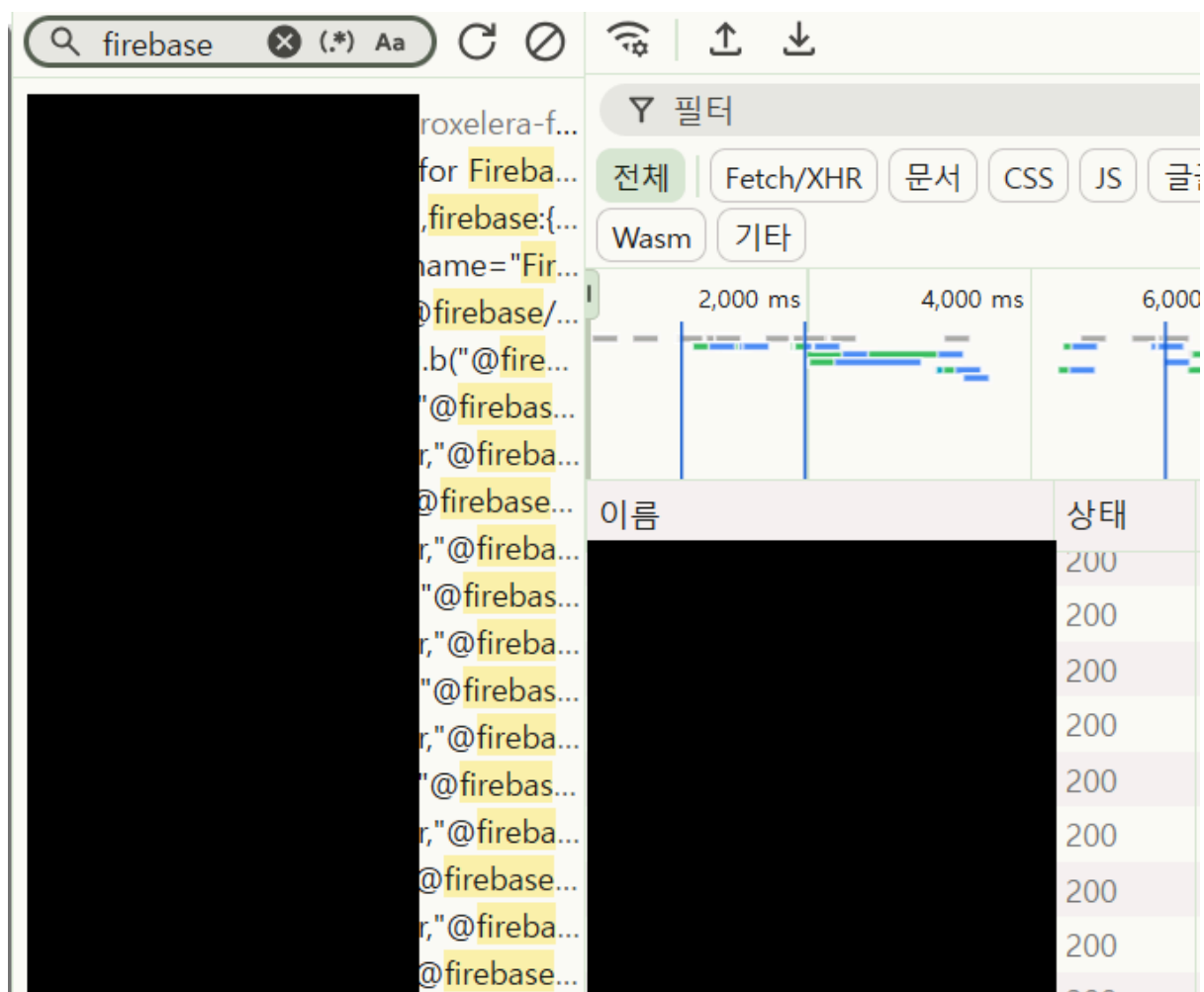
CRITICAL은 CVSS⁸ 등 공식 등급이 아니라, 후속 수동 검증이 필요한 대상을 선별하기 위한 자체 기준이다. 스캐너는 존재 여부만 판별할 뿐 실제 데이터를 다운로드·저장하지 않는다.

⁸ CVSS(Common Vulnerability Scoring System): 보안 취약점의 심각도를 국제적으로 통일된 기준에 따라 0~10점으로 수치화하는 공식 평가 체계.

2.2.3. 수동 검증

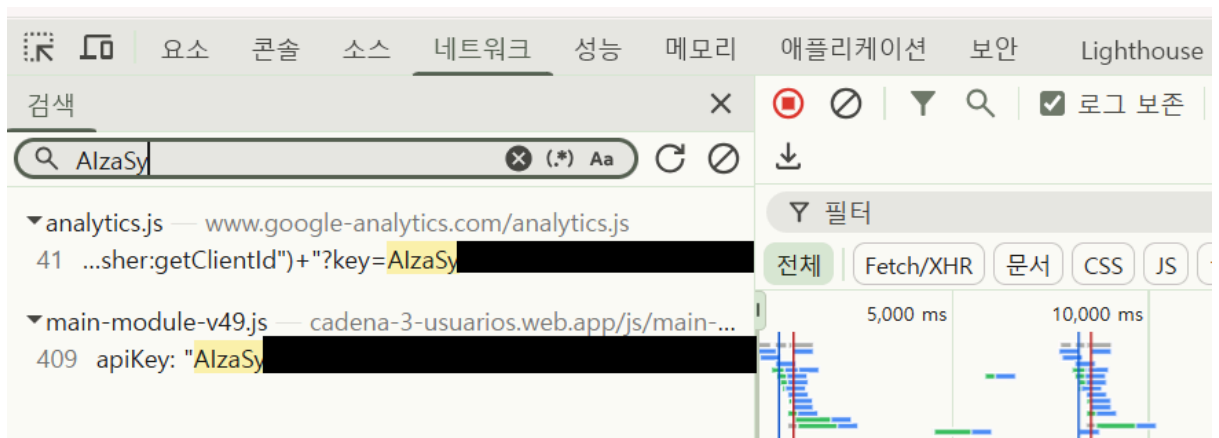
CRITICAL로 분류된 대상과 수동으로 찾은 웹페이지들을 다음 순서에 따라 사람이 직접 접근 가능 여부를 재확인하였다.

- **Firestore 사용 여부 확인:** 개발자도구(F12) 진입 → 페이지 새로고침(F5) → 네트워크 탭에서 firestore 검색해 관련 요청이 있는지 확인



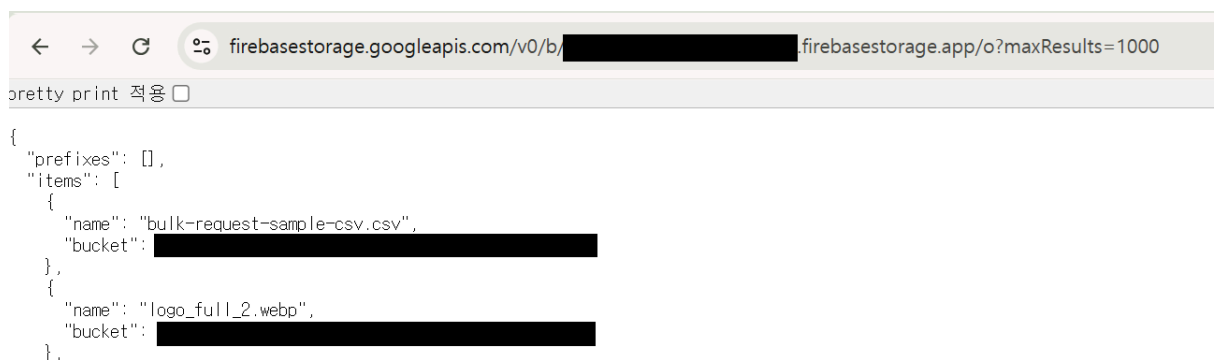
[사진 2-1] 개발자도구 네트워크 탭 firestore 검색 결과

- **설정값 확인:** AIzaSy⁹로 시작하는 apiKey 문자열을 검색해 찾고, 이를 통해 projectId·storageBucket 등 Firebase 설정값을 함께 확인



[사진 2-2] 네트워크 탭에서 apiKey(AlzaSy) 값 검색 결과

- **버킷 접근 검증:** 확인된 버킷 주소를 Storage API 형식 (firebasestorage.googleapis.com/v0/b/{버킷}/o)으로 브라우저에 직접 입력해 목록 조회 가능 여부 확인



[사진 2-3] Storage 버킷에 직접 접속해 파일 목록 확인

⁹ **AlzaSy:** Google API 키에 공통적으로 붙는 고정 접두어로, 이 문자열을 검색하면 코드 안에서 apiKey 값을 빠르게 찾아낼 수 있다.

- **다운로드 검증:** 목록에서 확인된 파일 중 하나를 대상으로

curl -o {파일명}

"https://firebasestorage.googleapis.com/v0/b/{버킷}/o/{파일경로}?alt=media&key={apiKey}" 형식으로 요청해 실제 다운로드 가능 여부 확인

```
C:\Users\test>curl -o sample.jpg "https://firebasestorage.googleapis.com/v0/b/modestrose.firebaseio.com/o/products%2F1770903783779_327.jpg?alt=media&key=AlzaSyCa7wmaV5yua68IqOMw1BjozilqRg6Z4Fw"
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           %             %             Dload  Upload   Total   Spent    Left   Speed
100 50109  100 50109    0     0  45340      0  0:00:01  0:00:01 --:--:-- 45429
```

[사진 2-4] Storage 파일 다운로드 성공 결과

목록에서 확인된 파일 주소에 다운로드 명령어(curl¹⁰)로 직접 접근한 결과, 파일 전체(50,109바이트)가 누락 없이 정상적으로 수신되었다. 이는 해당 파일이 인증 없이도 실제로 다운로드 가능한 상태였음을 의미한다.

```
목록 조회: 성공, 총 4개 파일 확인됨
- news/ProxeleraMysore.jpg
- news/SourceTOI.jpg
- news/SourceTOI.jpg
- news/proxelera-post-4.jpg
다운로드 가능 여부: 불가/오류 (status=402) - 샘플: news/ProxeleraMysore.
```

[사진 2-5] Storage 파일 다운로드 실패 결과

동일한 방식으로 다른 파일 주소에 접근을 시도하였으나, 서버가 상태 코드 402(오류)¹¹를 반환하며 요청을 거부하였다. 목록 조회는 가능했지만 실제 파일 내용은 받아올 수 없었던 사례로, 노출 수준이 파일마다 다를 수 있음을 보여준다.

¹⁰ **curl:** 터미널(명령어 창)에서 웹 서버에 직접 요청을 보내고 응답을 받을 수 있는 명령어 도구. 브라우저 없이도 파일 다운로드나 데이터 요청을 실행할 수 있다.

¹¹ **상태 코드 402:** 원래 "결제 필요(Payment Required)"를 뜻하는 코드이나, Firebase에서는 프로젝트의 무료 요금제 트래픽 한도를 초과했을 때 이 코드를 반환한다.

3. 탐지 결과

후보 탐지 도구, 디스콰이엇 등 개발자·프로젝트 소개 플랫폼, 구글 검색 연산자(site:)로 확보한 후보를 대상으로 동일한 스캐너로 인증 없는 상태에서 점검하였다.

- 후보 탐지 도구: 69개 스캔 → **CRITICAL 11건, UNKNOWN 58건**
- 디스콰이엇·구글 site: 검색으로 수집한 후보: 스캔 결과 **6건에서 Storage Open 확인**

완료 : 69개 대상 스캔 , 결과 저장 -> scan_results.csv

⚠ CRITICAL 11건 발견 - 즉시 스캔 중단 후 팀 체크리스트로 넘기세요 :

[사진 3-1] 후보 탐지 도구에서 나온 후보 69개 대상 자동 스캔 실행 및 CRITICAL 탐지 결과

CRITICAL 11건의 판정 근거는 다음과 같다.

판정 근거	건수	비고
Storage Open 확인	6건	공개 가능하며 단독으로는 데이터 접근 권한을 제공하지 않음
RTDB에서 Open 확인	3건	공개 가능하나, 실제 데이터 접근은 Security Rules의 제한을 받음
projectId 미확인 (도메인명 추정)	2건	Rules 미설정·방치 시 인증 없이 read/write 허용

[표 3-1] 후보 탐지 도구 후보 결과 CRITICAL 11건 판정 근거

디스콰이엇 등과 구글 검색 연산자(site:)로 Firebase 기반 페이지를 수집하고, 다음 절차로 점검하였다.

- 확인된 페이지: 50여 개
- projectId 미확인 대상 제외 후 스캐너로 점검
- 점검 결과: 대부분 Storage 닫힘, **6건만 로그인 없이 접근 가능**으로 확인

최종 검증 대상은 총 13건으로, 다음은 합산한 결과다.

- 자동 스캐너 CRITICAL 11건 중
 - Storage 열림 6건: 전체 포함
 - RTDB 열림 3건: 대표 사례 1건만 포함 (본 조사의 주 대상은 Storage이며, RTDB 열림 사례들은 양상이 유사해 대표 1건으로 같음)
 - projectId 미확인 2건: 제외
- 디스콰이엇·구글 검색 연산자로 확인한 수동 검증 6건

서비스명	판정 근거	목록 조회	다운로드
Proxelera	Storage 열림	O	X
npvplanner	Storage 열림	O	O
modestrose	Storage 열림	O	O
namsaiaan	Storage 열림	O	X
Ticket Booking	Storage 열림	O	O
Tikit	Storage 열림	O	X
proply.web.app	Storage 열림	O	O
sc2006app	Storage 열림	O	X
kvis-alumni	Storage 열림	O	X
cadena-3-usuarios	Storage 열림	X	X
bckstudentportal	Storage 열림	O	X
masterji-19f75	Storage 열림	O	X
akm-iot-firebase	Storage 열림	O	X

[표 3-2] 최종 검증 대상 13건

4. Firebase Storage Open 사례 및 위험 분석

이 분석을 통해 최종 검증 대상 13건을 4가지로 구분했다.

- 4.1. 실제 파일 접근 사례
- 4.2. 목록만 조회된 사례
- 4.3. 다른 Firebase 서비스가 열린 사례
- 4.4. 설정은 열려 있지만 실질 노출이 확인되지 않은 사례

각 유형은 대표 사례 하나를 중심으로 살펴본다.

4.1. 실제 파일 접근 사례 (npvplanner)

분석 결과

- 파일 목록 확인 가능

조회된 목록에서는 backups/ 경로 아래 총 1,405개의 백업 파일이 확인되었다. 파일들은 서로 다른 ID를 가진 29개의 폴더로 나뉘어 있었으며, 각 폴더는 별도의 사용자 또는 프로젝트로 추정된다. 폴더마다 거의 매일 자동으로 백업 파일이 생성되어 쌓이는 구조였다.

- 파일 다운로드 가능

목록에서 확인된 백업 파일 중 하나를 로그인이나 비밀번호 없이 직접 요청해본 결과, 실제 데이터가 정상적으로 다운로드되었다. 해당 파일의 크기는 약 403KB(412,367바이트)로, 문서 수십~수백 페이지 분량의 데이터가 담겨 있을 것으로 추정된다.

```
C:\Users\swimm>curl -o test.json "https://firebasestorage.googleapis.com/v0/b/npvplanner.firebaseio.com/o/backups%2F1768972802412toy0xfet%2F2026-08-22T01-15-07%2Fbackup_automati
c_1787361307634_p2hm9l.json?alt=media&key=REDACTED"
% Total    % Received % Xferd  Average Speed   Time    Time
     Time      Current                     Dload  Upload   Total   Spent
   Left  Speed
  0     0    0     0    0      0     0      0      0      0     0
  0     0    0     0    0      0     0      0      0      0     0
 71 402.7k  71 289.3k    0      0 126.6k      0    00:03    00:0
100 402.7k 100 402.7k    0      0 171.1k      0    00:02    00:0
100 402.7k 100 402.7k    0      0 170.2k      0    00:02    00:0
100 402.7k 100 402.7k    0      0 169.9k      0    00:02    00:0
  2      135.1k

C:\Users\swimm>dir test.json
C 드라이브의 볼륨에는 이름이 없습니다.
볼륨 일련 번호: E497-8C98

C:\Users\swimm 디렉터리

2026-08-23  오전 12:03                412,367 test.json
                  1개 파일                  412,367 바이트
                  0개 디렉터리 125,828,341,760 바이트 남음
```

[사진 4-1] npvplanner Storage 파일 다운로드 성공 결과

4.2. 목록만 조회된 사례 (sc2006app)

분석 결과

- 파일 목록 확인 가능

Storage API에 인증 없이 List 요청을 보낸 결과, 버킷 내 총 113개의 파일이 확인되었다.

파일명·저장 경로 등 목록 정보가 인증 없이 노출되었다.

- 파일 다운로드 실패

목록에 있는 파일을 다운로드 시도했으나 상태 코드 402(요금제 한도 초과)로 거부되었다.

파일이 보호된 것이 아니라, 해당 프로젝트의 무료 요금제 트래픽 한도 때문에 우연히 막힌 것으로 확인되었다.

```
C:\Users\swimm>curl -o test_file "https://firebasestorage.googleapis.com/v0/b/sc2006app.appspot.com/o/uploads%2Fabcd.jpg?alt=media&key=[REDACTED]"

% Total    % Received % Xferd  Average Speed   Time    Time     Time  Cu
rrent                        Dload  Upload   Total   Spent    Left   Sp
eed
100 406 100 406 0 0 1283 0 --:--:-- --:--:-- --:--:--
1288

C:\Users\swimm>type test_file
{
  "error": {
    "code": 402,
    "message": "Cloud Storage for Firebase no longer supports Firebase pro
jects that are on the no-cost Spark pricing plan. Please upgrade to the pa
y-as-you-go Blaze pricing plan to maintain access to your default bucket a
nd all other Cloud Storage resources. For details, see our FAQ: https://fi
rebase.google.com/docs/storage/faqs-storage-changes-announced-sept-2024"
  }
}
```

[사진 4-2] sc2006app Storage 파일 다운로드 실패 결과

4.3. 다른 Firebase 서비스가 열린 사례 (akm-iot-firebase)

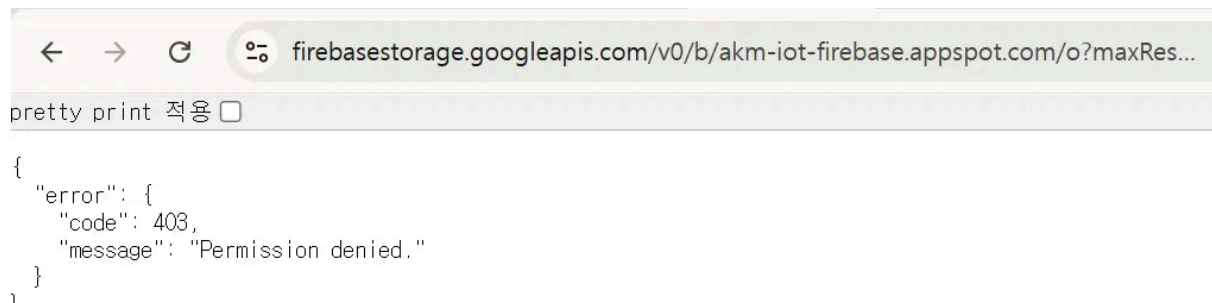
분석 결과

- Storage는 닫혀 있음

Storage에 파일 목록을 요청했지만 접근이 거부되었다. 즉 Storage는 제대로 보호되고 있었다.

- RTDB에서 로그인 없이 접근 가능 확인

같은 프로젝트의 Realtime Database에 로그인 없이 요청을 보내자, 데이터가 그대로 반환되었다. 즉 인증 없이 누구나 데이터를 들여다볼 수 있는 상태였다.



[사진4-3] akm-iot-firebase Storage 접근 거부 결과



[사진 4-4] akm-iot-firebase RTDB 로그인 없이 접근 가능

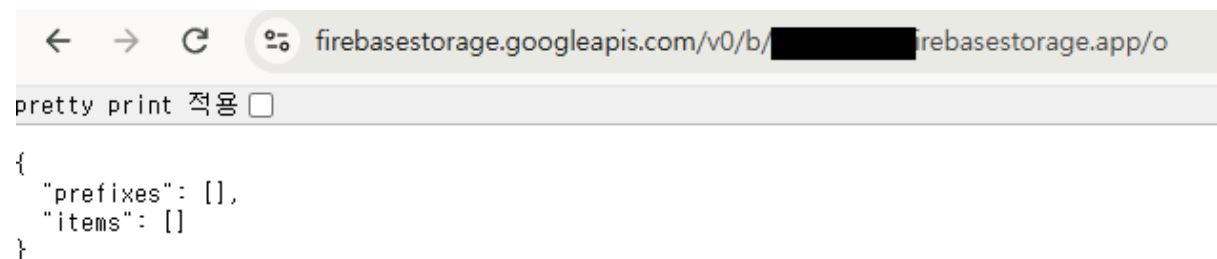
4.4. 설정은 열려 있지만 실질 노출이 확인되지 않은 사례 (namsaiaan)

분석 결과

- Storage 접근제어 설정 자체는 열려 있음

Storage에 파일 목록을 요청하자 정상적으로 응답이 왔다. 즉 인증 없이도 누구나 목록을 조회할 수 있는, 보안 설정이 열린 상태였다.

- 실제 조회된 파일은 0개



[사진 4-5] namsaiaan Storage 목록 조회 결과



[사진 4-6] namsaiaan 콘솔 확인 결과 파일 개수 0개

Conclusion

이번 조사에서 개발 초기 테스트 편의를 위한 Security Rules 전체 허용 설정이 배포 후에도 방치되어, 여러 Firebase 프로젝트에서 인증 없이 파일 목록 조회·다운로드가 가능한 상태로 확인되었다. 노출 수준은 사례마다 달랐으나, Storage뿐 아니라 RTDB 등 다른 서비스에서도 동일한 문제가 발견되어 서비스 전체에 대한 점검이 필요함을 보여준다.

Action Item

- Firebase 콘솔에서 Storage·RTDB·Firestore의 보안 설정(Rules)을 지금 바로 점검하고, 로그인한 사용자만 접근할 수 있도록 바꿔야 한다.
- 서비스를 배포하기 전 체크리스트에 **보안 설정 확인** 항목을 넣어서, 테스트할 때 쓰던 열린 설정이 실제 운영 중인 서비스까지 그대로 남지 않도록 관리해야 한다.
- 지금은 요금제 문제로 다운로드가 막혀 있거나 저장된 파일이 없는 경우도, 설정 자체는 열려 있는 상태이므로 위험이 남아 있다고 보고 계속 확인해야 한다.